

# GLOBAL VENDOR DATA SECURITY AND COMPLIANCE POLICY

|                                         |                               |                                                    |
|-----------------------------------------|-------------------------------|----------------------------------------------------|
| Document ID: POL-SEC-2026-V42           | Effective Date: June 11, 2026 | Classification: Confidential - Restricted          |
| Version Control: v4.2 (Supersedes v4.1) | Review Cycle: Annual          | Owner: Enterprise Legal & Cybersecurity Compliance |

## SECTION 1: OBJECTIVE & SCOPE

### 1.1 Objective and Purpose

The primary objective of this Global Vendor Data Security and Compliance Policy (the "Policy") is to establish a standardized, legally binding framework governing the protection, handling, transmission, and retention of Protected Corporate Data (as defined herein) by third-party entities. In an era of escalating distributed cybersecurity threats, sophisticated persistent threat vectors, and stringent transnational regulatory environments—including but not limited to the General Data Protection Regulation (GDPR), the California Consumer Privacy Act (CCPA) as amended by the CPRA, the Health Insurance Portability and Accountability Act (HIPAA), and the Federal Risk and Authorization Management Program (FedRAMP)—this Policy ensures that corporate information assets remain secure throughout their operational lifecycle when managed by external partners.

### 1.2 Scope of Application

This Policy applies unconditionally to all third-party suppliers, external service providers, independent contractors, systems integrators, software-as-a-service (SaaS) vendors, cloud service providers (IaaS/PaaS), and professional consultants (collectively referred to as "Vendors") who access, process, store, host, or transmit Protected Corporate Data, or who maintain logical or physical connectivity to the corporate network architecture. This Policy constitutes an integral, non-negotiable addendum to all primary master service agreements, statements of work, and purchase orders executed between the corporation and the Vendor.

### 1.3 Sub-processors and Downstream Contractor Constraints

The obligations set forth herein shall bind not only the Vendor but also any downstream sub-processors, subcontractors, secondary suppliers, or affiliate entities engaged by the Vendor to execute services under the primary contract. The Vendor shall remain fully and solely liable for the acts, omissions, and compliance postures of its sub-processors. Vendor is explicitly prohibited from onboarding, transferring, or provisioning access to Protected Corporate Data to any downstream entity without obtaining prior, express written authorization from the Corporate Information Security Officer (CISO) and the Enterprise Legal Compliance department. Any authorized sub-processor must execute an agreement containing data protection provisions no less restrictive than those specified within this Policy.

## SECTION 2: DATA ENCRYPTION & TRANSMISSION STANDARDS

### 2.1 Cryptographic Controls Framework

Vendors are mandated to enforce robust cryptographic mechanisms across all data states to protect corporate assets from unauthorized exposure, interception, or exploitation. Cryptographic keys must be managed independently of the data layers, utilizing dedicated Hardware Security Modules (HSMs) or enterprise key management systems that adhere to the Federal Information Processing Standards (FIPS) 140-3 Level 3 certification framework. Symmetric encryption must utilize advanced, non-deprecated mathematical algorithms with appropriate key lengths, while asymmetric operations must leverage robust public-key infrastructures capable of resisting contemporary cryptographic factorization mechanisms.

### 2.2 Data States and Standardized Requirements

The following matrix outlines the absolute minimum baseline standards acceptable for the encryption of Protected Corporate Data across various operational states. No deviation from these standards is permitted without an approved cryptographic exception waiver issued directly by the Corporate Infrastructure Security Committee.

| DATA STATE                                                              | MINIMUM ENCRYPTION STANDARD                                                                                               | AUTHORIZED PROTOCOLS & PARAMETERS                                                                          |
|-------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <b>Data-at-Rest</b><br>(Storage, DBs, Backups, Archives)                | Advanced Encryption Standard (AES) with a minimum key length of 256 bits (AES-256) utilizing XTS or CBC block modes.      | Full-disk encryption (FDE), transparent database encryption (TDE), and application-layer field encryption. |
| <b>Data-in-Transit</b><br>(Public and Untrusted Networks)               | Transport Layer Security (TLS) version 1.3 or higher. TLS 1.2 permitted strictly as fallback with approved cipher suites. | HTTPS, SFTP, SSHv2, IPsec VPN tunnels with Perfect Forward Secrecy (PFS) enabled. ECDHE-RSA/ECDHE-ECDSA.   |
| <b>Data-in-Use</b><br>(Volatile Memory, Processing States)              | Confidential Computing architecture or hardware-enforced Trusted Execution Environments (TEEs) where scalable.            | Intel SGX, AMD SEV, or homomorphic encryption frameworks for highly sensitive programmatic queries.        |
| <b>Mobile &amp; Removable Media</b><br>(Laptops, USBs, External Drives) | Hardware-bound AES-256 bit encryption tied to Trusted Platform Module (TPM) 2.0 microchips.                               | Enterprise Mobility Management (EMM) or Unified Endpoint Management (UEM) enforced policies.               |

### 2.3 Network Demarcation and Protocol Restrictions

The transmission of Protected Corporate Data across untrusted networks must strictly utilize the authorized protocols identified in Section 2.2. Cleartext protocols, including but not limited to HTTP, FTP, Telnet, SMTP without mandatory STARTTLS, and SMB v1/v2, are categorically banned from the Vendor infrastructure interacting with corporate systems. Any API endpoints exposed by the Vendor to exchange data must mandate mutual Transport Layer Security (mTLS) authentication, requiring valid cryptographic certificates issued by an approved, mutually recognized Certificate Authority (CA).

## SECTION 3: INCIDENT RESPONSE & DATA BREACH PROTOCOL

---

### 3.1 Incident Classification Framework

For the purposes of this Policy, security incidents are stratified into three categories based on severity, systemic risk, and impact on data integrity. A Category 1 incident represents localized scanning or unsuccessful probing. A Category 2 incident represents isolated malware or peripheral unauthorized access without data exfiltration. A Category 3 incident represents a confirmed or highly suspected unauthorized acquisition, access, alteration, disclosure, loss, or destruction of Protected Corporate Data, or any event that compromises the confidentiality, integrity, or availability of systems housing such data.

### 3.2 Mandatory Incident Notification and Timeline

**CRITICAL TIMELINE COMPLIANCE MANDATE:** In the event of a Category 3 data breach, the Vendor's designated security officer must initiate **Protocol Alpha** immediately upon detection. Failure to execute this protocol and provide official written notification to the corporate Incident Response Team at [security-alert@corporate-compliance.com](mailto:security-alert@corporate-compliance.com) within **4 hours** of discovery shall constitute an incurable material breach of the Master Services Agreement, rendering the Vendor liable for maximum statutory and liquidated damages, and authorizing immediate, unconditional termination for cause.

### 3.3 Execution of Protocol Alpha

Protocol Alpha requires the immediate mobilization of the Vendor's Executive Incident Response Team (EIRT). Within the initial 4-hour window, the Vendor must provide a preliminary incident report detailing the following parameters: (i) the nature and vectors of the security compromise; (ii) the precise categories and volume of Protected Corporate Data compromised or reasonably believed to be compromised; (iii) the specific identities of affected data subjects; (iv) the immediate containment mitigation strategies deployed; and (v) the designated technical point of contact steering the investigation. The Vendor shall not delay notification due to incomplete forensic variables; supplementary updates must be provided every two (2) hours thereafter as forensic discoveries crystallize.

### 3.4 Forensic Preservation and Investigation Collaboration

Upon invocation of Protocol Alpha, the Vendor shall immediately implement absolute litigation and forensic holds on all associated log repositories, network traffic captures, firewall registries, virtual machine snapshots, and physical drive media. The Vendor shall provide the corporation's internal cybersecurity experts and appointed third-party forensic firms unhindered, immediate physical and logical access to all compromised environments, system images, and logging platforms to facilitate an independent validation analysis. The Vendor shall bear all costs associated with the forensic investigation, including the retention of specialized external incident response counsel approved by the corporation.

## SECTION 4: LIABILITY, AUDIT RIGHTS, AND TERMINATION

---

### 4.1 Indemnification and Liability Caps

Notwithstanding any clause or limitation of liability provisions embedded within the primary Master Services Agreement, any breach of this Policy that results in a Category 3 data breach or severe regulatory non-compliance shall completely negate and invalidate any contractually established liability ceilings or caps. The Vendor agrees to indemnify, defend, and hold harmless the corporation, its corporate affiliates, officers, directors, employees, and agents against any and all third-party claims, civil lawsuits, class actions, regulatory enforcement actions, administrative fines, monetary judgments, legal defense expenses, and public relations remediation expenditures arising directly or consequentially from the Vendor's failure to abide by the security parameters defined herein.

### 4.2 Non-Compliance Penalties and Liquidated Damages

The corporation reserves the right to levy financial penalties and seek liquidated damages for operational non-compliance with this Policy. For every instance of non-compliance identified via audit or systemic discovery (excluding Category 3 breaches, which are governed by Section 3.2), the Vendor shall be assessed a daily non-compliance fine of Fifty Thousand Dollars (\$50,000 USD) per calendar day until full remediation is verified by corporate security personnel. Furthermore, if a regulatory body fines the corporation due to a security deficiency directly attributable to the Vendor's system architecture, the Vendor shall reimburse the corporation for the full amount of the fine within fifteen (15) business days of written demand.

### 4.3 Continuous and Annual Audit Rights

The corporation, or an appointed independent certified public accounting/security auditing firm, retains the unconditioned right to conduct comprehensive audits of the Vendor's physical facilities, logical technical environments, software development lifecycles, operational networks, personnel practices, and governance documentation. These audits shall occur on at least an annual basis, or immediately following any suspected security anomaly or policy deviation. The Vendor must provide full access to all requested systems, SOC 2 Type II reporting logs, ISO/IEC 27001 certification working papers, vulnerability scanning outputs, and static/dynamic application security testing reports. The Vendor shall remediate any high or critical risk vulnerability identified during an audit within fourteen (14) calendar days at its sole expense.

### 4.4 Immediate Termination Triggers

This Policy establishes specific, non-negotiable operational conditions that serve as immediate, automatic termination triggers for the overarching commercial relationship. The corporation may terminate all agreements with the Vendor instantly, without notice, without penalty, and without an opportunity for the Vendor to cure, upon the occurrence of any of the following events: (i) the failure of the Vendor to notify the corporation of a Category 3 breach within the mandatory 4-hour window; (ii) the discovery that the Vendor falsified, omitted, or manipulated vulnerability reports or compliance certifications; (iii) the intentional unauthorized deployment of a sub-processor without written consent; or (iv) a material failure to remediate an identified critical security vulnerability within the authorized 14-day remediation window. Upon termination, the Vendor must execute a verified, cryptographically secure sanitization of all corporate assets in accordance with NIST SP 800-88 Rev 1 standards and deliver a formal Certificate of Destruction within forty-eight (48) hours.